

HW06 - API Testing Report

Student: Nguyễn Phan Hùng Linh

Student ID: 23127081

Repository: <https://github.com/linhnph05/QA-HW06>

Self-assessed score: 100/100

1. Scope

I tested three EShop features:

Pool	Feature	Selected endpoints
A	FR-03 Forgot and reset password	POST /api/forgot-password, POST /api/reset-password
B	FR-09 Discount coupons	POST /api/apply-coupon, POST /api/coupon-usage
C	FR-12 Access control	GET /api/admin/users plus related protected admin endpoints listed below

I used the API specification, security rules SEC-01 to SEC-07, and the running backend at <http://127.0.0.1:3000>.

Exact endpoints used

For FR-03, I sent requests to:

- POST /api/forgot-password to request an OTP.
- POST /api/reset-password to validate the OTP and change the password.

For FR-09, I sent requests to:

- POST /api/apply-coupon to validate a coupon and calculate the discount.
- POST /api/coupon-usage to test coupon usage records and usage-limit state.

For FR-12, GET /api/admin/users was the representative access-control API. I also tested these protected endpoints to check whether role enforcement was consistent:

- GET /api/admin/users
- DELETE /api/admin/users/:id
- GET /api/admin/orders
- PUT /api/admin/orders/:id/status
- GET /api/coupons
- POST /api/admin/coupons
- DELETE /api/admin/coupons/:id
- POST /api/admin/import-products
- POST /api/products

The collection also used POST /api/register and POST /api/login during setup. These requests created test users and obtained normal-user and admin tokens. I did not count the setup requests as selected APIs.

2. AI-First Test Design and Human Audit

I guided three helper AI sessions separately. Each helper received only the relevant feature, endpoints, rules, and required test design areas. Each produced exactly 35 draft cases. I then checked every case against the

specification and code.

Feature	AI cases	Valid	Invalid	Incomplete	Human additions	Final cases
FR-03	35	30	1	4	5	40
FR-09	35	29	1	5	5	40
FR-12	35	30	1	4	5	40
Total	105	89	3	13	15	120

The detailed generation, audit, and extension files are in test-cases/. The exact helper prompts and outputs are attached through AI-AUDIT-REPORT.md.

The human additions focus on cases that AI often misses: account enumeration, rate limits, concurrent OTP use, coupon usage races, numeric overflow, known-secret JWT forgery, stale roles, deleted users, and admin self-delete.

3. Execution

I converted the reviewed cases to one data-driven Postman collection and ran it with Newman 6.2.2. A collection pre-request script adds X-Student-Id: 23127081 to every request.

Feature	Executed	Passed	Failed	Failed assertions
FR-03	40	17	23	25
FR-09	40	20	20	26
FR-12	40	17	23	23
Total	120	54	66	74

There were 269 assertions: 195 passed and 74 failed. Failures were not hidden because many show real security or business-logic bugs. Evidence is in newman/newman-report.html, newman/newman-results.json, results/*.csv, images/newman-summary.png, and images/student-id-console.png. The console screenshot proves that the pre-request script added X-Student-Id: 23127081 to the executed requests.

4. Postman and Newman Features Used

- Collection folders for the three selected features.
- Collection variables and an environment file for the base URL, accounts, tokens, OTPs, IDs, and coupon data.
- A collection-level pre-request script for the student header.
- Request-level test scripts and dynamic state sharing.
- Data-driven CSV files and one combined 120-case CSV.
- Positive, negative, boundary, state, security, and schema assertions.
- Newman CLI execution with CLI, JSON, and HTML reporters.
- GitHub Actions execution and uploaded JSON result artifact.

I did not use a monitor or mock server because the local EShop backend and GitHub Actions runner were enough for this assignment.

5. Bugs

I reported nine genuine bugs in both reports/bug-report.md and GitHub Issues:

1. Four-digit OTP with no expiry state: <https://github.com/linhnph05/QA-HW06/issues/1>
2. Forgot-password account enumeration: <https://github.com/linhnph05/QA-HW06/issues/2>
3. Weak and plaintext reset password: <https://github.com/linhnph05/QA-HW06/issues/3>
4. Wrong percent coupon formula: <https://github.com/linhnph05/QA-HW06/issues/4>
5. Wrong minimum-total boundary: <https://github.com/linhnph05/QA-HW06/issues/5>

6. Coupon API lacks JWT enforcement: <https://github.com/linhnph05/QA-HW06/issues/6>
7. Admin role is not enforced: <https://github.com/linhnph05/QA-HW06/issues/7>
8. Profile update allows role escalation: <https://github.com/linhnph05/QA-HW06/issues/8>
9. Hard-coded JWT secret permits forgery: <https://github.com/linhnph05/QA-HW06/issues/9>

Every issue includes its own screenshot. The Issues-page evidence is `images/github-issues.png`.

6. CI/CD

The workflow in `.github/workflows/api-tests.yml` checks out the SUT submodule, installs Node.js and Newman, starts the backend, runs all 120 baseline cases, and uploads the Newman JSON artifact.

- All-passing commit: `98f77c3aa64d70662ba6aa3b4d4cfad9fed421e8`
- All-passing run: <https://github.com/linhnph05/QA-HW06/actions/runs/32109080739>
- One-failure commit: `b6e490c6de73f3ae811cb0a0f6e0bab75b7d93ef`
- One-failure run: <https://github.com/linhnph05/QA-HW06/actions/runs/32109235988>
- Final restored green run: <https://github.com/linhnph05/QA-HW06/actions/runs/32109618742>

The red sample changes only one expected status from 200 to 418. It produces exactly one failed assertion. I restored it afterward. More detail is in `reports/ci-cd-report.md`.

7. AI-Driven Test Generator Skill

I created the reusable `api-test-generator` Agent Skill. It reads Markdown endpoint definitions and writes a CSV test draft. The draft includes domain, boundary, security, header, and schema templates. All generated rows start as INCOMPLETE so a human must audit them. The skill validator passed, and the FR-03 demonstration produced `test-cases/fr03-skill-demo.csv`.

The self-designed diagram and pseudocode are in `reports/api-test-generator-design.md`.

8. AI Critique

The full 200–300 word critique is in `reports/ai-critique.md`. My main lesson is that AI is useful for broad coverage, but a human must challenge its assumptions and connect separate security facts.

9. AI Audit Appendix

I use AI tools for the tasks declared in `AI-AUDIT-REPORT.md`. That appendix contains only my interactions with the three helper AIs. It does not include the conversation with the assistant that helped manage this repository.

10. Self-Assessment

No.	Criteria	Grade	Self-Assessed Grade
1	FR-03 full pipeline	30	30
2	FR-09 full pipeline	30	30
3	FR-12 full pipeline	30	30
4	Agent Skill	10	10
	Total	100	100/100